Ex2 Friday: pocket guide

Test 09:30 to 16:00. One 30-minute break: **email your supervisor at the START and at the END.** Screenshots: **max 5 pages A4.** Upload to **Blackboard**. Submission is **final**. **No AI chat, no messaging. Actual start:** _____

Rules

1. Stuck 10 minutes? Say “the next step is ____”. Write your assumption. Move on.
2. Retype your prepared work in your own words. Do not paste.
3. Protect **Malware** and **Threats** first (merit and distinction).
4. Honest labels: **Observed** or **Known**. Never write “secure”.

Schedule

#	Block	Clock	Done
1	Start	09:30 to 09:45	☐
2	Intel table	09:45 to 10:45	☐
3	Malware table	10:45 to 11:30	☐
4	Threat table	11:30 to 12:15	☐
	Break + 2 emails	12:15 to 12:45	☐
5	Lab evidence, screenshots	12:45 to 13:15	☐
6	Assurance strategy	13:15 to 13:50	☐
7	Justification	13:50 to 14:50	☐
8	Final check, UPLOAD	14:50 to 15:30	☐
9	Buffer, no new work	15:30 to 16:00	☐

Email at break start: ☐ _____ Email at break end: ☐ _____

What earns what

Topic	Pass	Merit	Distinction
Malware	Mechanisms	Obfuscation	Own tools
Threats	Enriched view, lab test	Services and processes	Mitigations
Assurance	Strategy	none	none
Legal	Evidence handling	none	none

1. Start (09:30 to 09:45)

Done when: folders are ready and the hash is re-checked.

☐ Write your real start time on page 1

☐ Make folder `Ex2_Day2`: screenshots, outputs, notes

☐ Copy in your bring-in files

☐ Re-check the sample: `Get-FileHash -Algorithm SHA256 <file>`

☐ Write the time and value in notes

☐ Matches the hash in Table 1? If not, STOP and write a note

☐ File not on this PC? Write “hash from CAPE report (Fig 2)”

☐ Open the v11 brief. Tick the 5 yellow topics

2. Intel table (09:45 to 10:45)

Done when: every row has all 8 columns, and 2 external sources are cited.

☐ One real lookup per row, short result in Enrichment

☐ Hash: VirusTotal (family, detections)

☐ Domains: WHOIS (owner, created date)

☐ IPs: ASN lookup (who owns the range)

☐ Read one NCSC page and one OWASP page

☐ Write title, URL, date accessed for each

☐ Reliability: High (seen in CAPE or 2+ sources), Medium, Low

☐ Fill Confidence and Action

☐ Mark Microsoft, Akamai, Let’s Encrypt as allowlisted, with reason

☐ Mark `1.0.0.0` etc. as false positives (version strings)

☐ Write 2 lines: what changed after enrichment

3. Malware table (10:45 to 11:30)

Done when: Table 2 is checked and the merit paragraph is written.

☐ Each Fig really shows what the row claims

☐ Check every ATT&CK ID against Fig 7

☐ IDs not in Fig 7 (T1566): look up on attack.mitre.org

☐ Can’t confirm an ID? Delete it

☐ Each row says **Observed** or **Known**

☐ Exfiltration is **Known**, not observed

MERIT (do not skip)

☐ Write 3 lines: how I saw past the packing

☐ Static: one import, high entropy (Figs 1, 2)

☐ Sandbox: process injection (Fig 3)

☐ YARA hits on the process dumps (Fig 4)

☐ Write 2 lines: why the triage said “low” but YARA said Agent Tesla

☐ Write 1 line: what is mine vs the pre-written script

DISTINCTION (only if true)

☐ Did you script or adapt a tool yourself? If not, skip. Do not claim it.

4. Threat table (11:30 to 12:15)

Done when: 6 rows complete, a mitigation on each.

☐ Write 3 lines: assets, entry points, trust boundaries

☐ Boundaries: device to API, API to database

☐ Say the SaaS assumption

☐ Tested? = **No** unless you have evidence

MERIT (do not skip)

☐ Row 4 helpdesk reset: 1 sentence, how an employee enables it unknowingly

☐ Row 5 supplier access: 1 sentence, same question

☐ Row 6 API tokens: Tested? = Yes, Figs 9a and 9b

DISTINCTION

☐ Every row has a mitigation in the Control column

Break (12:15 to 12:45)

☐ Email your supervisor: break starting. Time: _____

☐ Eat. Water. Walk. Look far away.

☐ Email your supervisor: break ended. Time: _____

5. Lab evidence and screenshots (12:45 to 13:15)

Done when: lab test written up, screenshots fit in 5 pages of A4.

☐ Target was the Ex1 sync app only. Note it in the log

☐ Write 4 lines: 200 invalid tokens, all 401, no lockout seen

☐ Finding: no rate limiting seen

☐ Mitigation: rate limit, lockout, long random tokens

☐ Write “200 attempts is a small sample”

☐ sqlmap: 752 x 400 responses

☐ sqlmap result is **inconclusive**, not “safe”

☐ Paste Figs 1 to 9b into one document

☐ Check the page count: 5 or fewer

☐ Number each figure, add a one-line caption

If over 5 pages, cut in this order

1. Crop Fig 7 harder
2. Stack 9a and 9b together
3. Merge Figs 5 and 6
4. Drop Fig 8

Figure map

Fig	Shows
1	Triage report (static)
2	CAPE static, packed warning, VT/MWDB/Bazaar
3	Process tree
4	YARA hits on dumps
5	Modified files
6	Registry keys
7	ATT&CK matrix
8	DNS requests
9a, 9b	Token test (single, 200)

6. Assurance strategy (13:15 to 13:50)

Done when: objectives, a 5-row test plan, and the four approaches. **Pass only: stop on time.**

☐ What needs assuring: patient records, clinician devices, sync API

☐ 3 security objectives

☐ 3 acceptance criteria you can measure

☐ Test plan table: Test, Scope, Expected, Owner, Evidence, Priority

☐ 5 rows or more

☐ Priority rule: asset criticality, threat likelihood, vulnerability severity

☐ Four approaches, one example each:

☐ … design and implementation

☐ … intrinsic (give 2)

☐ … extrinsic (give 1: independent pen test, with benefits and limits)

☐ … operational policy and process

☐ 2 lines: “trusted” versus “trustworthy”

☐ 2 lines: how third-party testing contributes

☐ Findings: record, rate, fix, retest

☐ Retest triggers: release, supplier change, new threat

7. Justification (13:50 to 14:50)

Done when: 900 to 1,100 words, retyped in your own words, no [CONFIRM] left.

☐ Open the draft. Read **section 1** only

☐ Check each claim against your figures and tables

☐ Delete anything not true of your work

☐ Retype section 1 in your own words (about 12 min)

☐ Resolve each [CONFIRM]

☐ Repeat for section 2, then 3, then 4

☐ Section 3 must match your block 6 strategy

☐ Add one thing you did that the draft missed

☐ Every Fig and Table mentioned by number

☐ Count words (body only). Target 1,000

Under 900? Add a sentence on what you did not do or would add next. **Over 1,100?** Cut the longest sentence in the longest section.

8. Final check and UPLOAD (14:50 to 15:30)

☐ Words 900 to 1,100

☐ Every Fig and Table mentioned by number

☐ Screenshots 5 pages A4 or fewer

☐ Same hash in Table 1 and the justification

☐ RoE, tables, figures and justification are all in the upload

☐ No [CONFIRM] or [N] left

☐ Own work vs pre-written is clear

☐ No sample, credentials or real personal data in the upload

☐ File names clear, formats as the pack asks

☐ Upload to Blackboard

☐ Shows as submitted; screenshot the confirmation

☐ Upload failed? Retry, then tell your supervisor. Note the time

Submitted at: _____

9. Buffer (15:30 to 16:00)

Do not start new work.

If you run short of time

1. Malware merit paragraph + Threat table
2. Hash + evidence-handling paragraph
3. Short assurance: objectives, test plan, four approaches
4. A short honest justification beats a missing one